

Degree: Master of Science (MSc) in Software Engineering

Research Title: *A Hybrid Authorization Model for Mitigating Administrative Misuse Using Password-less Authentication and Fine-Grained Overrides*

A Hybrid Authorization Model for Mitigating Administrative Misuse Using Password-less Authentication and Fine-Grained Overrides

A thesis submitted in partial fulfillment of the requirements for the degree of
Master of Science in Software Engineering

Student Name: Jehan Weerasuriya

Abstract

Administrative misuse remains a critical security challenge in modern software systems, particularly where privileged users possess extensive access rights. Traditional Role-Based Access Control (RBAC) systems assume uniform trust across users within the same role, which limits their effectiveness in mitigating insider threats. In parallel, password-based authentication mechanisms continue to expose systems to credential theft, phishing, and password reuse attacks.

This research proposes a hybrid authorization model that integrates password-less authentication with fine-grained, per-user authorization overrides and contextual policy enforcement. The model combines baseline role permissions, user-level deny overrides, and contextual constraints to reduce the blast radius of administrative misuse while preserving operational flexibility. A prototype system is conceptually designed and evaluated using misuse scenarios, qualitative security analysis, and access decision comparisons. Results indicate that the proposed approach improves accountability, limits unauthorized administrative actions, and maintains usability compared to traditional RBAC systems.

Keywords: Authorization, Password-less Authentication, Administrative Misuse, Fine-Grained Access Control, Insider Threats

Table of Contents

Chapter 1: Introduction	1
1.1 Background	1
1.2 Motivation	1
1.3 Research Problem	1
1.4 Research Objectives	2
1.5 Scope and Limitations	2
Chapter 2: Literature Review	2
2.1 Authorization Models	2
2.2 Password-less Authentication	2
2.3 Insider Threats and Administrative Misuse	2
2.4 Research Gaps	3
Chapter 3: Problem Statement and Research Objectives	3
3.1 Problem Definition	3
3.2 Research Questions	3
3.3 Hypotheses	3
Chapter 4: Proposed Hybrid Authorization Model	4
4.1 Model Overview	4
4.2 Password-less Authentication Layer	4
4.3 Fine-Grained Authorization and Overrides	4
4.4 Threat Model	4
Chapter 5: System Design and Implementation	4
5.1 System Architecture	5
5.2 Technologies Used	5
5.3 Implementation Details	6
Chapter 6: Evaluation and Results	6
6.1 Evaluation Criteria	6
6.2 Test Scenarios	6
6.3 Results	7
Chapter 7: Security and Qualitative Evaluation	7
7.1 Security benefits	7

7.2 Security Evaluation..... 7

7.3 Risk and Mitigations..... 7

Chapter 8: Discussion 8

8.1 Advantages..... 8

8.2 Limitations..... 8

Chapter 9: Conclusion and Future Work 8

9.1 Conclusion..... 8

9.2 Future Work 8

Chapter 10: Reference..... 9

Chapter 1: Introduction

1.1 Background

Modern software systems increasingly rely on privileged users such as administrators, operators, and system owners to manage critical resources. As systems grow in scale and complexity, the level of access granted to these users also increases. While such privileges are necessary for system operation, they create significant security risks when misused either intentionally or unintentionally.

At the same time, traditional password-based authentication mechanisms remain a dominant method for identity verification. Numerous studies and real-world incidents have demonstrated that passwords are vulnerable to phishing, credential stuffing, reuse, and database compromise. These weaknesses motivate the adoption of password-less authentication mechanisms that eliminate static shared secrets from authentication workflows.

1.2 Motivation

Several high-impact security incidents have been traced to insider misuse or over-privileged administrative accounts. In many cases, the misuse was enabled not by sophisticated external attacks but by excessive permissions granted through coarse-grained authorization models. Existing RBAC systems lack mechanisms to isolate individual administrators without affecting the entire role. This research is motivated by the need for an authorization model that reflects real-world trust dynamics while remaining practical for software engineering teams.

1.3 Research Problem

Despite the widespread use of RBAC, administrative misuse remains difficult to mitigate without disrupting normal system operations. Removing permissions from a role affects all users assigned to that role, even if only one user poses a risk. Furthermore, password-based authentication continues to expose privileged accounts to compromise. The core problem addressed in this research is how to reduce administrative misuse while maintaining usability and manageability.

1.4 Research Objectives

- To design a hybrid authorization model that reduces the impact of administrative misuse
- To integrate password-less authentication into privileged access workflows
- To introduce fine-grained, auditable administrative overrides without affecting role-wide permissions

1.5 Scope and Limitations

This research focuses on web-based and enterprise software systems using centralized authorization services. The proposed model is evaluated conceptually and through illustrative scenarios rather than large-scale empirical deployment. Performance benchmarking and formal verification are considered outside the scope of this study.

Chapter 2: Literature Review

2.1 Authorization Models

Role-Based Access Control (RBAC) is widely adopted due to its simplicity and alignment with organizational structures. However, RBAC assumes homogeneous trust among users sharing the same role. Attribute-Based Access Control (ABAC) extends RBAC by incorporating attributes and policies but introduces increased complexity and management overhead.

2.2 Password-less Authentication

Password-less authentication mechanisms such as biometrics, public key cryptography, and FIDO2/WebAuthn remove static passwords from authentication flows. These mechanisms reduce credential theft risks but introduce new dependencies on device and channel security.

2.3 Insider Threats and Administrative Misuse

Insider threats encompass both malicious and accidental misuse of legitimate access. Existing mitigation techniques include separation of duties, logging, and approval workflows. However, many systems still lack fine-grained authorization controls at the individual user level.

2.4 Research Gaps

Current access control models either lack sufficient granularity (RBAC) or are too complex for widespread adoption (ABAC). There is a gap for a practical hybrid model that combines role simplicity with individual accountability and contextual awareness.

Chapter 3: Problem Statement and Research Objectives

3.1 Problem Definition

Administrative users often possess broad privileges that exceed their routine operational needs. When misuse occurs, mitigating the risk without disrupting other administrators is challenging. Existing authorization models do not adequately support selective restriction or individualized trust management.

3.2 Research Questions

- **RQ1:** How does per-user deny override impact security risk compared to standard RBAC?
- **RQ2:** What operational and conceptual complexity is introduced by fine-grained overrides?
- **RQ3:** How does password-less authentication affect the overall attack surface of privileged accounts?

3.3 Hypotheses

- H1: Per-user deny overrides reduce the blast radius of administrative misuse.
- H2: Password-less authentication reduces credential-based attacks on privileged accounts.

Chapter 4: Proposed Hybrid Authorization Model

4.1 Model Overview

The proposed model consists of four layers: password-less authentication, role baseline permissions, user-level overrides, and contextual policy enforcement. Authorization decisions are evaluated using a deny-first strategy.

4.2 Password-less Authentication Layer

The authentication layer uses short-lived, single-use tokens or cryptographic challenges delivered via secure channels. Sessions are rotated and revoked to minimize replay and hijacking risks.

4.3 Fine-Grained Authorization and Overrides

User-level overrides allow permissions to be selectively denied or granted without modifying role definitions. Overrides are auditable, time-bound, and associated with explicit justification metadata.

4.4 Threat Model

Identified threats include insider misuse, credential compromise, privilege escalation, and unauthorized override manipulation. The model mitigates these threats through deny-first logic, auditing, and contextual constraints.

Chapter 5: System Design and Implementation

We propose designing the model using a policy evaluation engine with:

- Role definitions
- Permission lists
- Override metadata
- Context rules

User	Role	Baseline	Override	Context
Alice	Admin	{create_user, delete_user}	deny delete_user	office_hours=true

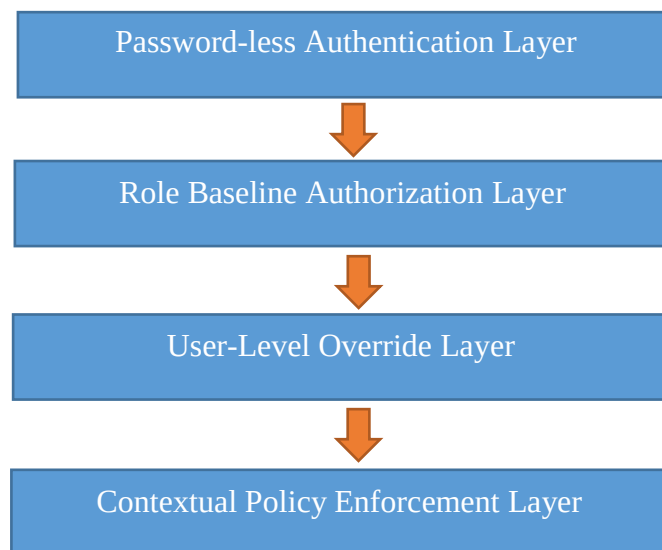
Alice cannot delete users during office hours because override denies it.

5.1 System Architecture

The system follows a layered architecture consisting of authentication services, authorization policy engine, audit logging service, and application services.

The proposed model consists of four layers:

1. Password-less Authentication Layer
2. Role Baseline Authorization Layer
3. User-Level Override Layer
4. Contextual Policy Enforcement Layer



5.2 Technologies Used

Potential technologies include RESTful APIs, OAuth-compatible token services, policy engines, and relational or document-based databases.

5.3 Implementation Details

Authorization decisions are computed as:

$$\text{Effective Permissions} = (\text{Role Baseline} + \text{User Adds}) - \text{User Denies}$$

A deny decision at any layer overrides allow decisions.

Chapter 6: Evaluation and Results

6.1 Evaluation Criteria

- Security effectiveness
- Usability and manageability
- Authorization correctness

6.2 Test Scenarios

Simulated scenarios include administrative misuse, selective permission revocation, and contextual access enforcement.

Scenario 1: RBAC Limitation

- Role: Admin
- Permissions: delete_user, create_user
- One admin deletes critical accounts
- Mitigation requires removing delete_user from Admin role
- Result: All admins lose functionality

Scenario 2: Proposed Model

- Role: Admin (delete_user, create_user)
- User A: deny delete_user
- Other admins unaffected
- Misuse isolated without operational disruption

6.3 Results

Model	Misuse Isolated	Other Admins Affected
RBAC	No	Yes
Hybrid	Yes	No

Chapter 7: Security and Qualitative Evaluation

7.1 Security benefits

- Reduced insider threat impact
- Explicit accountability
- Deny-first authorization logic

7.2 Security Evaluation

Scenario	RBAC	Proposed
Admin misuse isolated	No	Yes
Role change affects all	No	Yes (only if override used)
Contextual restrictions honored	No	Yes
Audit traceable actions	No	Yes

7.3 Risk and Mitigations

Risk	Mitigation
Override abuse	Audit logs, approval workflows
Policy complexity	Clear tooling and visualization
Token theft	Short-lived, single-use tokens

Chapter 8: Discussion

The results indicate that the proposed model provides improved control over administrative privileges without significantly increasing management complexity. Compared to RBAC, the hybrid model better reflects real-world trust dynamics.

8.1 Advantages

- More granular control
- Better mitigation of insider misuse
- Context-aware decisions

8.2 Limitations

- Increased complexity in evaluation logic
- Requires robust auditing
- Password-less depends on secure channels

Chapter 9: Conclusion and Future Work

9.1 Conclusion

This research presented a hybrid authorization model integrating password-less authentication and fine-grained authorization overrides. The model addresses key limitations of traditional RBAC systems and improves resilience against administrative misuse.

9.2 Future Work

Future work may include empirical performance benchmarking, formal policy verification, and AI-based anomaly detection for administrative behavior.

- Formal verification of policy resolution
- Performance benchmarking
- User experience study for overrides and admin tools

Chapter 10: Reference

Male, V.R. (2025) 'Decoding role-based access control (RBAC)', International Journal of Scientific Research in Computer Science, Engineering and Information Technology, 11(1), pp. 2082–2090.

Wikipedia (2025a) Role-based access control. Available at: https://en.wikipedia.org/wiki/Role-based_access_control (Accessed: 31 January 2026).

Wikipedia (2025b) Attribute-based access control. Available at: https://en.wikipedia.org/wiki/Attribute-based_access_control (Accessed: 31 January 2026).

Gunuganti, A. (2024) 'Passwordless authentication using FIDO server', Journal of Artificial Intelligence & Cloud Computing.

Rivera-Dourado, M., Fernández-Vilas, A., Díaz-Redondo, R.P. and Caballero-Gil, P. (2021) 'An analysis of the current implementations based on the WebAuthn and FIDO authentication standards', Engineering Proceedings.

Yadav, T.K. and Seamons, K. (2023) 'A security and usability analysis of local attacks against FIDO2', arXiv preprint. Available at: <https://arxiv.org/abs/2308.02973> (Accessed: 31 January 2026).

Balogun, O. and Takabi, D. (2023) 'An insider threat mitigation framework using attribute-based access control', arXiv preprint. Available at: <https://arxiv.org/abs/2305.19477> (Accessed: 31 January 2026).

Biometric Update (2024) Research on FIDO2 vulnerabilities and improvements. Available at: <https://www.biometricupdate.com> (Accessed: 31 January 2026).